

Automatisiere deine Microsoft 365 Governance – Best Practices um Compliance zu garantieren

Die Gastgeber



Tobias Maestrini

https://www.linkedin.com/in/tobiasmaestrini
https://tobias-maestrini.ch

Daniel Kordes

https://www.linkedin.com/in/daniel-kordes
https://www.youtube.com/@durm365



Heutige Agenda

- Governance in Microsoft 365
- Open Source Tooling
- Bestehende Ressourcen & Standards
- easyGovernance (for fans: «easyG»)



Governance in Microsoft 365

«Governance» in Microsoft 365

beschreibt den **Rahmen aus Richtlinien, Prozessen, Rollen und Zuständigkeiten**, der eine **effiziente, sichere und vorschrifts-mäßige** Nutzung der Dienste in M365 gewährleistet.

Arbeitsdefinition von «Governance in Microsoft 365»

Technische Richtlinien für die Verwaltung und den Betrieb von M365-Diensten sowie Tools zur Berichterstattung über Richtlinien in Bezug auf Sicherheit, Transparenz und Nachvollziehbarkeit.

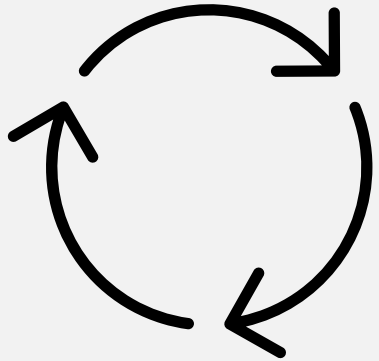
Governance in Microsoft 365

- Fehlende M365 Governance = hohes Risiko! 🧨
- Datenschutzverletzungen: ungewollter Datenabfluss (Freigaben, Auffindbarkeit, KI-Integration)
- Ineffiziente Ressourcennutzung: (übermässig) hohe Lizenzkosten, «falsche» Nutzung von Diensten
- Fehlende Transparenz und Kontrolle über den Datenverkehr (Data Loss Prevention DLP)
- Unreguliertes IAM = kein Überblick, wer welche Rechte im Tenant hat



Governance in Microsoft 365 [...]

- M365 Governance erfolgreich umsetzen
- Definition eines unternehmensspezifischen Frameworks oder Regelwerks basierend auf Unternehmensrichtlinien
- Verschiedene «technische Richtlinien» für Dienste (Konfigurationsvorgaben)
- Einen (wiederkehrenden) Prozess definieren: Überwachen – Berichten – Besprechen / Anpassen



BEISPIEL

SERVICE SETTINGS IN M365 (AUSWAHL)

Org settings

«Best Practises?»

Services | Security & privacy | Organization profile

	Name ↑	Description
	Customer lockbox	Set requirements for data access.
	Help & support query collection	Choose whether Microsoft can use your organization's support queries to improve help & support.
	Idle session timeout	Automatically sign users out of the Microsoft 365 web apps after a period of inactivity.
	Microsoft Graph Data Connect applications	Approve and deny requests from apps to access your organization's Microsoft 365 data.
	Name pronunciation	Allow all users in your organization to set the pronunciation of their name across Microsoft 365.
	Password expiration policy	Set the password policy for all users in your organization.
	Privacy profile	Set the privacy statement of your organization.
	Privileged access	Set scoped access for privilege tasks and data access within your organization.
	Pronouns	Allow all users in your organization to set their pronouns across Microsoft 365.
	Self-service password reset	Let users reset their own forgotten passwords rather than contacting your organization's IT for help.
	Sharing	Control access for people outside your organization.

Sharing

Use these settings to control sharing at the organization level in SharePoint and OneDrive.
Learn more about managing sharing settings

External sharing

Content can be shared with:

SharePoint | OneDrive

Most permissive

- **Anyone** — Users can share files and folders using links that don't require sign-in.
- **New and existing guests** — Guests must sign in or provide a verification code.
- **Existing guests** — Only guests already in your organization's directory.
- **Only people in your organization** — No external sharing allowed.

Least permissive

You can further restrict sharing for each individual site and OneDrive. Learn how

More external sharing settings

File and folder links

Choose the type of link that's selected by default when users share files and folders in SharePoint and OneDrive.

- ○ Specific people (only the people the user specifies)
- ○ Only people in your organization
- ◉ Anyone with the link



Open Source Tooling

Querying: PnP.PowerShell und M365 CLI

open source

PnP PS POWERSHELL

https://github.com/pnp/powershell

https://pnp.github.io/powershell/cmdlets

SPO management

`Get-PnPTenant` 🚀

PPL management

keine Power Platform Settings Cmdlets

`Get-PnPPowerPlatformEnvironment`
`Get-PnPPowerPlatformSolution`
`Get-PnPPowerApp / [...]-PnPFlow`

PnP CLI MICROSOFT 365

https://github.com/pnp/cli-microsoft365

https://pnp.github.io/cli-microsoft365/cmd/docs

SPO managementg

`m365 spo tenant settings [list|...]` 🚀

PPL management

`m365 pp tenant settings [list|set]` 🚀
`m365 pp environment [list|get]`
`m365 pp solution [...]`
`m365 pa [...] / m365 flow [...]`

DEMO

QUERYING USING PNP.POWERSHELL AND M365 CLI



APIs mittels HTTP-Anfragen (Reverse Engineering)

**Was tun, wenn es keine (dokumentierten) Ressourcen –
oder keine PoSh-Cmdlets – für die gesuchten Einstellungen gibt?**

1. Nach verfügbaren **Graph-Endpunkten (Graph API)** suchen
   (🧨 PoSh-Modul-Abhängigkeiten 🤯)
2. **Reverse Engineering:** APIs der Admin Centers analysieren
   - Das jeweilige Admin Center aufrufen (MAC / TAC / PAC / …)
   - Den «Untersuchen»-Modus (F12) im Browser verwenden
   - Den «Netzwerk»-Tab öffnen und Aufzeichnung starten
   - Die Funktion im Admin Center aufrufen (zur Einstellung navigieren)
   - Die Endpunkte und Payloads analysieren, die der Browser aufruft
3. Eigenes **«Einstellungsmodul» implementieren** / einbinden



Bestehende Ressourcen & Standards

Bestehende Richtlinien (Empfehlung)

SCuBA

«Secure Cloud Business Applications» der amerikanischen Cyber-Abwehrbehörde (CISA)

adressiert Microsoft 365 (M365) und Google Workspace (GWS)

https://www.cisa.gov/resources-tools/services/secure-cloud-business-applications-scuba-project

CIS M365 Benchmark

Verschiedene Benchmarks des Center für Internet Security (CIS)

adressiert Microsoft 365 (M365) und weitere Dienste / Tools / Betriebssysteme

https://www.cisecurity.org/benchmark/microsoft_365

mehr...

«The blueprint» p… **eingestellt**

adressiert Microsoft 365 (M365)

https://www.linkedin.com/posts/sam-brazier-hollins_oobe-theblueprint-m365-activity-7072018293129166848-6LVf/

BEISPIEL

CIS für M365: Sicherheit & Datenschutz

1.3.1 (L1) Ensure the 'Password expiration policy' is set to 'Set passwords to never expire (recommended)' (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Microsoft cloud-only accounts have a pre-defined password policy that cannot be changed. The only items that can change are the number of days until a password expires and whether or whether passwords expire at all.

Rationale:

Organizations such as NIST and Microsoft have updated their password policy recommendations to not arbitrarily require users to change their passwords after a specific amount of time, unless there is evidence that the password is compromised, or the user forgot it. They suggest this even for single factor (Password Only) use cases, with a reasoning that forcing arbitrary password changes on users actually make the passwords less secure. Other recommendations within this Benchmark suggest the use of MFA authentication for at least critical accounts (at minimum), which makes password expiration even less useful as well as password protection for Entra ID.

Impact:

When setting passwords not to expire it is important to have other controls in place to supplement this setting. See below for related recommendations and user guidance.

- Ban common passwords.
- Educate users to not reuse organization passwords anywhere else.
- Enforce Multi-Factor Authentication registration for all users.

Richtlinie

Beschreibung des Inhalts mit Erläuterungen und Umsetzungshinweisen

Begründung (Relevanz)

Auswirkungen / Impact



BEISPIEL

CIS für M365: SharePoint Online

7.2.3 (L1) Ensure external content sharing is restricted (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

The external sharing settings govern sharing for the organization overall. Each site has its own sharing setting that can be set independently, though it must be at the same or more restrictive setting as the organization.

The new and existing guests option requires people who have received invitations to sign in with their work or school account (if their organization uses Microsoft 365) or a Microsoft account, or to provide a code to verify their identity. Users can share with guests already in your organization's directory, and they can send invitations to people who will be added to the directory if they sign in.

The recommended state is `New and existing guests` or less permissive.

Rationale:

Forcing guest authentication on the organization's tenant enables the implementation of controls and oversight over external file sharing. When a guest is registered with the organization, they now have an identity which can be accounted for. This identity can also have other restrictions applied to it through group membership and conditional access rules.

Impact:

When using B2B integration, Entra ID external collaboration settings, such as guest invite settings and collaboration restrictions apply.

Richtlinie

Beschreibung des Inhalts mit Erläuterungen und Umsetzungshinweisen

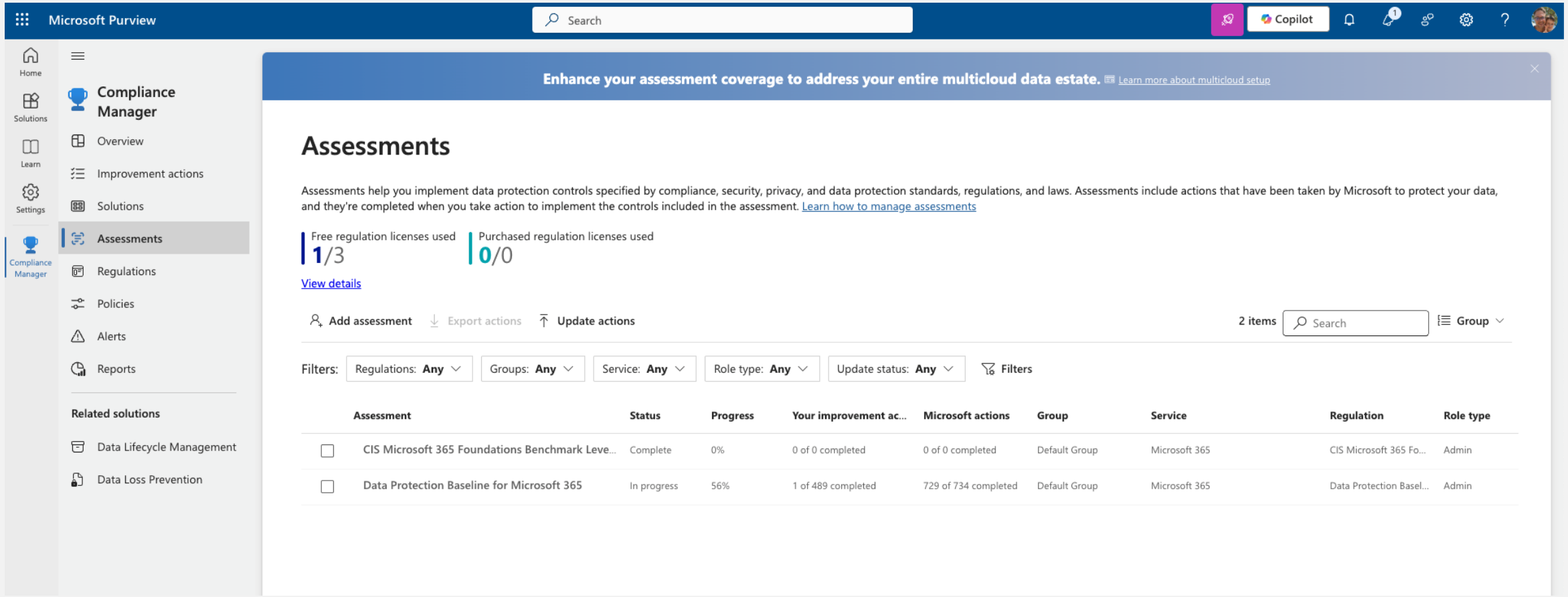
Begründung (Relevanz)

Auswirkungen / Impact



BEISPIEL

CIS Benchmark Assessment in M365: Purview «Compliance Manager»



BEISPIEL

Community Tools

Maester

- Securityfokus
- CIS, CISA, EIDSCA, ORCA,...
- Einfach zu bedienen
- Org Settings fehlen

Microsoft 365 DSC

- Sehr mächtig
- Nicht nur reporting, sondern auch Anpassungen
- Keine Baselines oder Frameworks
- Durchaus komplex zu bedienen

easyGovernance

- M365 Governance mit Org settings
- OOBE & CIS Basis
- Fertige Baselines
- Einfach zu bedienen
- Aktuell wenige M365 Services
- Noch in der Entwicklung

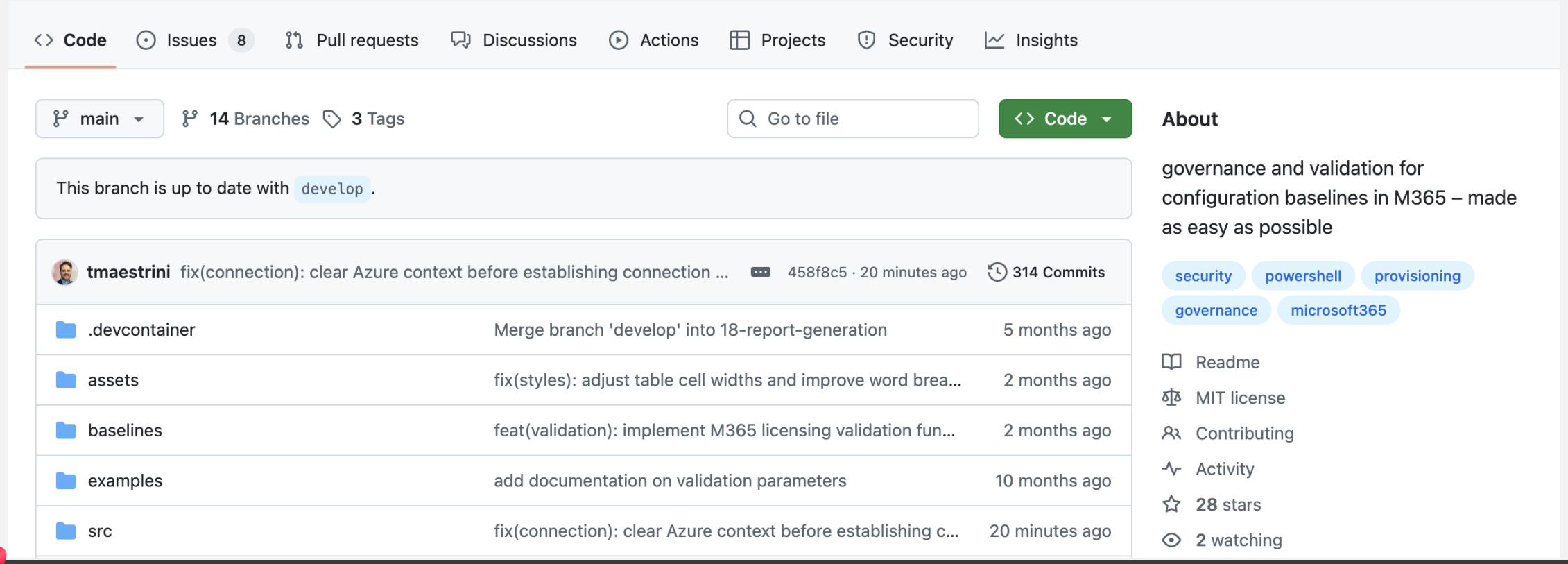


easyGovernance (for fans: «easyG»)

Open source Project auf Github

https://github.com/tmaestrini/easyGovernance 🚀





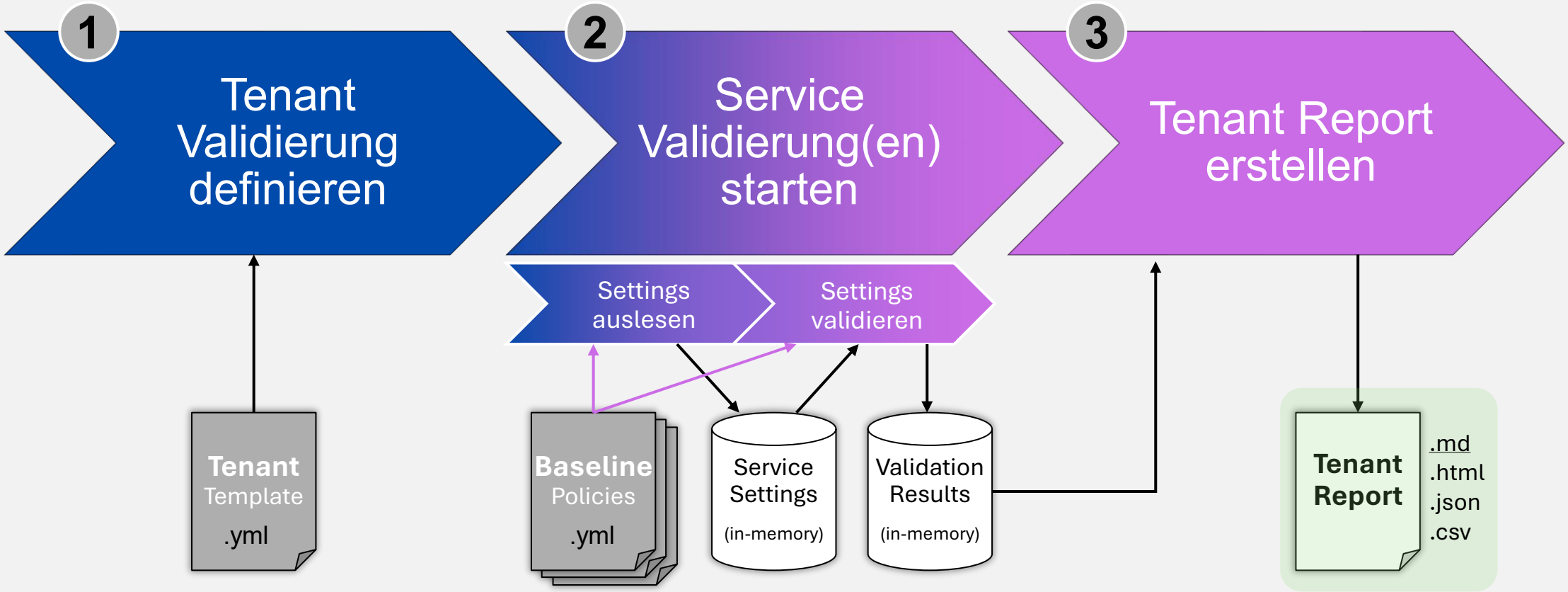
DEMO

EASY GOVERNANCE



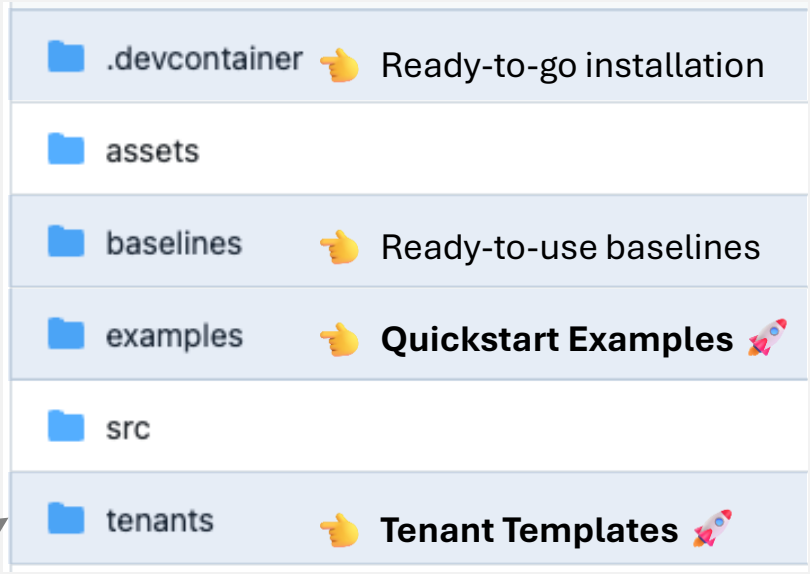
Tenant Validation Routine *(General procedure)*

3 Schritte zur Erstellung eines Tenant Reports»



Validierung und Reporting

Recap: die Struktur – ready to go 🚀 «easy approach»



1. Tenant validieren:

```powershell
# Validate a given tenant from settings file
Import-Module .\src\Validation.psm1 -Force
$result = Start-Validation -TemplateName "[tenantname].yml" -ReturnAsObject -KeepConnectionsAlive -ReloadBaselines
```

2. Report erstellen:

```powershell
# Generate a report in directory ./output (optionally as HTML)
New-Report -ValidationResults $result -AsHTML
```

THANK YOU.

DANIEL

TOBIAS

EASY GOVERNANCE